

Diagrama de Fluxo de Trabalho para a Avaliação de Risco de Segurança de uma Aplicação Web

Coluna 1: Fluxo Principal

- Definição do Escopo
- Identificação de Ativos
- Identificação de Ameaças
- Identificação de Vulnerabilidades
- Identificação de Impactos
- Identificação de Controles
- Identificação de Medidas de Mitigação
- Identificação de Medidas de Resposta
- Identificação de Medidas de Recuperação
- Identificação de Medidas de Prevenção

Coluna 2: Descrição Detalhada

Este documento descreve o processo de avaliação de risco de segurança de uma aplicação web. O processo é dividido em etapas, cada uma com sub-etapas e referências. O objetivo é identificar e avaliar os riscos de segurança da aplicação, permitindo a tomada de decisões sobre as medidas de mitigação necessárias.

Coluna 3: Sub-etapas

1. Definição do Escopo: Identificar o objetivo da avaliação, o escopo da aplicação e os recursos envolvidos.

2. Identificação de Ativos: Identificar os ativos da aplicação, incluindo dados, funcionalidades e recursos.

3. Identificação de Ameaças: Identificar as ameaças potenciais à aplicação, incluindo ataques de hackers, malware e phishing.

4. Identificação de Vulnerabilidades: Identificar as vulnerabilidades da aplicação, incluindo falhas de segurança e configurações incorretas.

5. Identificação de Impactos: Identificar os impactos potenciais das ameaças e vulnerabilidades, incluindo danos financeiros, reputacionais e legais.

6. Identificação de Controles: Identificar os controles existentes na aplicação, incluindo firewalls, sistemas de detecção de intrusão e políticas de segurança.

7. Identificação de Medidas de Mitigação: Identificar as medidas de mitigação necessárias para reduzir os riscos, incluindo atualizações de software, treinamento de usuários e testes de penetração.

8. Identificação de Medidas de Resposta: Identificar as medidas de resposta necessárias para lidar com incidentes de segurança, incluindo planos de resposta a incidentes e sistemas de monitoramento.

9. Identificação de Medidas de Recuperação: Identificar as medidas de recuperação necessárias para restaurar a aplicação após um incidente, incluindo backups e planos de recuperação de desastres.

10. Identificação de Medidas de Prevenção: Identificar as medidas de prevenção necessárias para evitar a ocorrência de incidentes, incluindo auditorias de segurança e monitoramento contínuo.

Coluna 4: Referências

Este documento contém referências para as normas e padrões utilizados na avaliação de risco de segurança. As referências incluem:

- ISO 27001: Norma internacional para sistemas de gestão de segurança da informação.
- ISO 27005: Norma internacional para gestão de risco de segurança da informação.
- NBR 15474: Norma brasileira para avaliação de risco de segurança da informação.
- OWASP: Organização para a Segurança de Aplicações Web, com guias e ferramentas para avaliação de risco.
- MITRE ATT&CK: Framework de ameaças para identificar e classificar ataques cibernéticos.

Coluna 5: Conclusão

Este documento conclui o processo de avaliação de risco de segurança da aplicação web. O resultado da avaliação é um relatório de risco de segurança, que fornece uma visão geral dos riscos identificados e das medidas de mitigação recomendadas. O relatório é usado para tomar decisões sobre a priorização das medidas de mitigação e para monitorar a eficácia das medidas implementadas.